

Potential security vulnerability in create_pyi #8853

✓ Closed



kmulka-bloomberg opened on Jul 20, 2024

...

Describe the bug

According to this report, there is a security vulnerability in gradio. It looks like it has been in the wild without a patch for a few weeks.

[GHSA-9v2f-6vcg-3hgv](#)

Have you searched existing issues?

☒ I have searched and found no existing issues

Reproduction

```
import gradio as gr

# Define the events
events = ["on_load"]

pyi_code = gr.component_meta.create_pyi('.__class__.__base__.__subclasses__()[139].__init__')
```

Screenshot

No response

Logs

No response

System Info

4.38.1

Severity

Blocking usage of gradio



kmulka-bloomberg added **bug** on Jul 20, 2024

abidlabs on Jul 20, 2024 · edited by abidlabs

Edits ▾

Member



Hi **@kmulka-bloomberg** as far as I understand, this is not a real security vulnerability since it only affects a user who runs specifically crafted code that happens to use gradio library. But if someone is executing code from a third party, then they are already executing arbitrary code anyways, so the fact that jinja2 is injecting some code is not a real additional security threat. If I'm misunderstanding something, please let me know.



abidlabs closed this as **not planned** on Jul 20, 2024

kmulka-bloomberg on Jul 20, 2024

Author



@abidlabs Thanks for the response. I don't understand the ComponentMeta code enough to understand if user-contributed data (via the gradio web UI or API) would be fed to the create_pyi function. Maybe you could help me / others understand what the purpose of this function is and if it is possible user-contributed data could be passed through.

kmulka-bloomberg on Jul 20, 2024

Author



Wondering if you or someone from the gradio team could dispute the creation of the CVE if you believe it is not a vulnerability.



kmulka-bloomberg mentioned this on Jul 20, 2024



[\[GHSA-9v2f-6vcg-3hgv\] Gradio was discovered to contain a code injection vulnerability via the component /gradio/component_meta.py github/advisory-database#4622](#)

abidlabs on Jul 20, 2024

Member



We'll look into it. I'll reopen this issue for now



abidlabs reopened this on Jul 20, 2024



abidlabs changed the title **Security Vulnerability in create_pyi** Potential security vulnerability in create_pyi on Jul 20, 2024



abidlabs self-assigned this on Jul 20, 2024

abidlabs on Jul 23, 2024

Member



I used this form <https://cveform.mitre.org/> to dispute the security vulnerability. I used this script to provide an alternate way where a user could simply monkeypatch the gradio library to produce a similar effect:

```
import os
import re

import gradio
gradio_dir = os.path.dirname(gradio.__file__)
components_file_path = os.path.join(gradio_dir, 'components.py')

with open(components_file_path, 'r') as file:
    file_contents = file.read()

pattern = r'(class Textbox\(..*?\):\s+def __init__(self,.*?\):\s+)'
replacement = r'\1\n        print("Custom code executed: Textbox is being created")\n'

new_file_contents = re.sub(pattern, replacement, file_contents, flags=re.DOTALL)

with open(components_file_path, 'w') as file:
    file.write(new_file_contents)

print("gradio package has been modified. Custom code will now execute whenever Textbox is in")
```



abidlabs closed this as completed on Jul 23, 2024

Carbaz on Oct 15, 2025

@abidlabs

This vulnerability is still being reported and it does as CRITICAL.

Got this on my pipeline vulnerabilities scan step:

```
gradio==5.49.1 [1 vulnerability found]
-> Vuln ID 72086: CVE-2024-39236, CVSS Severity CRITICAL
  *Disputed* Affected versions of Gradio contain a code injection
  vulnerability via the component /gradio/component_meta.py. This
  vulnerability is triggered via a crafted input.
  # NOTE: The supplier di...
  For more information: https://data.safetycli.com/v/72086/eda
No known fix for gradio==5.49.1 to fix 1 vulnerability
Learn more: https://data.safetycli.com/p/pypi/gradio/eda/?from=5.49.1
```

- <https://data.safetycli.com/v/72086/eda/>

Whatever it's or not actually a vulnerability, or a CRITICAL one, I guess you should try to fix code or the vuln report,

currently Gradio have the burden of a reported critical, arbitrary code injection, vulnerability which should be concerning enough for any one and a deterrent to it's usage.

Not everyone have the knowledge, skill or time to dig in on the tech details about it, and not every one that does is in a position to authorize usage of critical, injection type, risky components...

freddyaboulton on Oct 16, 2025

Collaborator

...

Hi [@Carbaz](#) ! Totally get your frustration. The CVE is shown as disputed here (<https://nvd.nist.gov/vuln/detail/CVE-2024-39236>). Not sure yet how we can actually close. The NVD says that they're not in charge of verifying whether or not vulnerabilities are legit so not sure who to reach out to. I will look into it but would appreciate any tips you may have.

Q. How do I dispute a CVE in the NVD?

A. For information regarding a particular CVE dispute or to dispute the legitimacy of a CVE; You should contact the CVE Assignment Team using the form at cveform.mitre.org. The NVD does not participate in the vulnerability disclosure or the CVE publication process, nor are we involved in the determinations for the legitimacy of any CVE. These are all functions of the CVE Program and occur upstream from NVD efforts. As such, we do not have any insight into the nature of disputed CVEs aside from the information that is publicly available in the CVE Description, public forums, or advisories.

Carbaz on Oct 16, 2025

Hi [@Carbaz](#) ! Totally get your frustration. The CVE is shown as disputed here (<https://nvd.nist.gov/vuln/detail/CVE-2024-39236>). Not sure yet how we can actually close. The NVD says that they're not in charge of verifying whether or not vulnerabilities are legit so not sure who to reach out to. I will look into it but would appreciate any tips you may have.



Sorry, I do not have experience or knowledge on how to contest or solve a vulnerability report, I wasn't even able to un-blacklist a mistakenly blacklisted IP in the past 😞

I just wanted to highlight the situation to you, that a year old, and disputed, vulnerability report is still ringing alarms on scans of your product on main code scanners as Safety or Snyk (at least snyk says it's medium, not critical)

Maybe fill the form again, and again, to annoy someone there so they take a look at it? 😊

I don't even get to understand how the exploit works or how can be used to inject code to judge it myself 😊

[Michellehbn](#) mentioned this on Oct 16, 2025

[\[GHSA-9v2f-6vcg-3hgv\]](#) Gradio was discovered to contain a code injection vulnerability via the component `/gradio/component_meta.py` [github/advisory-database#6324](#)

Sign up for free to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

[abidlabs](#)

Labels

bug

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

▼

No branches or pull requests

Participants

